B.P. venkata Uday kumar
192411203

SAVEETHA

INSTITUTE OF MEDICAL AND TECHNICAL SCIENCES
(Declared as Deemed to be University under Section 3 of UGC Act 1956)

Programme: **B.E / B.Tech**

Course Code: **ITA1439**

Course Name: **Ethical Hacking**

Duration: **1: 30 Hr**

Date: **02-11-2026**

Max Marks: **50 Marks**

35 70 50

CONTINUOUS INTERNAL ASSESSMENT 1

Course Outcomes
On successful completion of the course, students will be able to:

CO	Course Outcome Statement
CO1	Apply the principle of the foundational concepts of ethical hacking, including types of hackers, ethical principles, legal frameworks, and the role of responsible disclosure in cybersecurity.
CO2	Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Answer all the Questions

1. A private bank hires a security firm to test its internet-banking portal before launch. In the same month, a former employee uses old credentials to view customer records, a student runs a downloaded attack tool against the portal "to see what happens", and an activist group defaces the bank's website. Define the term hacker and classify each person or group, including the hired testers, as white hat, black hat, grey hat, script kiddie, hacktivist or insider, with reasons. Explain the ethical principles the testers must follow, such as written authorization, agreed scope, confidentiality, avoiding harm and honest reporting. **(CO1) (BL3)**

2. A student finds an SQL injection flaw in the e-learning portal of another university that exposes the marks and contact details of about 20,000 students, without having permission to test it. The student is considering posting the details on social media, reporting privately to the university, or offering the details in exchange for payment. Analyze the legal position of the student under the Information Technology Act, 2000, with reference to unauthorized access and data theft. Compare full disclosure, responsible (coordinated) disclosure and bug-bounty programmes, and recommend the most appropriate disclosure process and timeline for this case with justification. **(CO1) (BL4)**

3. (a) A college authorizes its security club to carry out a penetration test of the student portal. Before any testing begins, the team must define how the engagement will be conducted. Apply the ethical-hacking methodology by listing its phases — reconnaissance, scanning, gaining access, maintaining access and reporting — and state the objective of each phase. Explain what a written rules-of-engagement / authorization document must specify (in-scope targets, time window, permitted and prohibited techniques, and the point of contact) to keep the engagement lawful, in-scope and non-destructive. **(CO1) (BL3) (5 Marks)**

(b) A security team is authorized to assess the internet exposure of a retail company that uses the domain retailco.example. Explain the difference between passive and active footprinting, and describe how the team would use WHOIS lookups, nslookup or dig, and search-engine operators (site:, filetype:, intitle:) to collect information about the company. For any THREE of these sources, state one item of information it may reveal and the security risk it creates. **(CO2) (BL3) (5 Marks)**

4. During an authorized assessment, a tester runs "dig axfr example.com @ns1.example.com" and the name server returns the full zone, including www (A, 203.0.113.10), vpn (A, 203.0.113.25), hr-portal (A, 10.10.5.20), dev-db (A, 10.10.8.15), mail (MX, priority 10) and a TXT record listing the SPF mail servers. Explain how a DNS zone transfer works and why it is meant only between primary and secondary name servers. Analyze what an attacker could learn from each record to plan further attacks, and recommend countermeasures such as restricting transfers, TSIG authentication and split-horizon DNS. **(CO2) (BL4)**

5. An organization receives an e-mail that appears to come from its IT help desk, asking employees to "verify" their passwords through a link. Later, a caller claiming to be from the help desk asks the accounts section for a one-time password, and a visitor without an ID card follows an employee through a secured door. Identify each attack type (phishing, vishing, pretexting or tailgating) and the psychological principles used, such as authority and urgency. Describe how an authorized social engineering assessment of this organization should be planned, and propose technical, procedural and awareness-based countermeasures. **(CO2) (BL3)**

B.P. venkata uday kumar
192411203
ITA1439

A hacker is a person who uses computer skills to identify weaknesses or access computer systems.

Types of hackers:

1) White hat: works legally with permission to find security weaknesses.
2) Black Hat: Accesses systems illegally to steal data or cause damage.
3) Gray Hat:- Accesses systems without permission by may not have harmful intention.
4) Hacktivist:- Hacks systems for political or social causes.
5) Insider: Misuses access given by an organization.

Examples:-

* Hired testers - white Hat
* former employee - Insider.
* Activist group - Hacktivist.

Ethical principales:

1. obtain written permission.
2. Follow the agreed testing scope.
3. Maintain confidentiality.
4. Avoid damaging systems and Report vulnerabilities honestly.

2)

the information technology Act, 2000 protects computer systems and data from unauthorized access.

Important section?

1. Section 43: Deals with unauthorized access, downloading and copying data.
2. section 66: covers dishonest or fraudulent computer-related acts.
3. section 72: Deals with breach of confidentiality and privacy in specified circumstances.

the

Types of Disclosure

1. Full Discloser :- Publicly reveals the vulnerability details
2. Responsible Disclosure :- privately inform the organizations and allocas time to fix the problem.
3. Bug Bounty :- Researchers report vulnerabilites through an official programme and may receive rewards.

Recommended Method :-

Responsible disclosure is the best option.

* stop further testing.
* Do not download or share student data.
* Report the vulnerability privately.
* coordinate public disclosure after fixing the issue.

3)

a) ethical hacking is a systematic process of identifying security weaknesses.

phases of ethical Hacking:

1- Reconnaissance: collect information about the target.
2. scanning: identify open ports, services and vulnerabilites.
3. Gaining Access: Test Vulnerabilities to check system securi
4. Maintaing Access :- check whether access can be maintained
5. Reporting: prepare a report with vulnerabilitys and solutions.

Rules of engagement :-

1) In-scope Targets :- Specify systems allowed for testing.
2) Time window :- Mention testing datas and Times
3) Permitted Techniques: List allowed testing Methods
4) Prohibited Techniques: Avoid destructive activities
4) Point of contact. :- Provide responsible person's details

Footprinting is the process of collecting information about a target organization.

Type of footprinting:-

1) Passive footprinting: collects information from public sources without directly interacting with the target
2) Active footprinting:- collects information by directly interacting with target systems

Tools used:-

1. WHOIS : finds domain registration details
2. dig : finds IP addresses and DNS records
3. Search engine operators: site:retailco.example - finds website pages.
   - filetype:pdf - finds PDF documents.

4)

DNS (Domain Name system) converts domain names into IP addresses.

→ DNS zone transfer is the process of copying DNS records from a primary server to a secondary server.

working:

1. secondary server requests DNS records.
2. Primary server verifies the request.
3. if authorized, records are transferred.
4. secondary server updates its DNS information.

Information Revealed

1. www: Identifies the website server IP.
2. VPN : Reveals the VPN server.
3. hr-portal : Reveals the HR portal's internal IP.
4. mail : Reveals the email serve.

countermeasures:
1- Restrict zone transfers to authorized servers.
2. use TSIG authentication.
3. Implement split-horizon DNS.
4. Monitor DNS requests.
5. Secure and update DNS servers.

5) social engineering is a technique used by attackers to manipulate people into revealing confidential information

Types of Attacks.
1. Phishing: fake emails used to steal information.
2. vishing: fake phone calls used to obtain sensitive information.
3. pretexting: creating a false identity to gain trust

psychological principles:-
1. Authority: Pretending to be an important offical.
2. Urgency: creating pressure to act quickly.
3. Trust: Gaining confidence through fake identities.
4. fear: threatening account suspension.

countermeasures:-
Technical: use spam filters and MFA
Install anti-phishing protection.
Procedural: verify suspicious requests.
Awareness: * conduct cyber security training.
* Teach employees to identify fake emails and calls.